

Manual 22 — Implementação controlada de segurança em nuvem

Localização controlada pt-BR — desenvolvimento

****Ordem da série:**** 22

****Fonte inglesa vinculante:**** blob `a056997ce359c3a37acc5b931e5f808cc09921be`

****Estado de referência principal:**** Cloud Security Alliance Cloud Controls Matrix (CCM) v4.1

****Limite:**** Guia de implementação original. Orientação nativa de provedores é evidência de implementação e não substitui leis aplicáveis, normas independentes nem a intenção dos controles CSA. Crosswalks são mapeamentos, não equivalências. Esta tradução do projeto é não oficial e não implica registro, atestação ou certificação CSA STAR.

1. Governança de nuvem e modelo operacional

Definir responsabilização executiva, proprietários de segurança, responsabilidades de plataforma e aplicações, aceitação de risco, autoridade de arquitetura, onboarding de serviços e hierarquia de políticas. Evidências: carta de governança, RACI, padrões, exceções e decisões de gestão.

2. Escopo, tenancy, contas, assinaturas, projetos e landing zones

Manter escopo autoritativo de organizações, tenants, contas, assinaturas, projetos, regiões, ambientes e proprietários. Usar provisionamento e tagging governados. Evidências: inventários, hierarquias, definições de landing zone e reconciliação com APIs do provedor.

3. Responsabilidade compartilhada e alocação contratual

Documentar responsabilidades conforme modelo de serviço, implantação, capacidades, contratos e serviços gerenciados. Evidências: matrizes, cláusulas, declarações de controles, obrigações do cliente, lacunas e gatilhos de reavaliação.

4. Avaliação de risco e registros de decisão de arquitetura

Avaliar riscos considerando sensibilidade, criticidade, caminhos de identidade, exposição, dependência do provedor, concentração regional, cadeia de suprimentos e resiliência. Evidências: avaliações, modelos de ameaça, ADRs, premissas, risco residual e aprovações.

5. Federação de identidade, autenticação e acesso privilegiado

Centralizar identidade quando viável, exigir autenticação forte, limitar privilégios e proteger identidades de emergência. Evidências: federação, MFA, funções privilegiadas, elevações, revisões e testes de break-glass.

6. Identidade de workloads e principais de serviço

Governar contas de serviço, identidades gerenciadas, federação de workloads, principais, certificados e credenciais automatizadas. Preferir credenciais de curta duração. Evidências: inventário, propriedade, permissões, idade, políticas de confiança e rotação.

7. Arquitetura de rede, segmentação, ingresso e egresso

Definir padrões aprovados, segmentação, roteamento, ingresso da Internet, egresso, conectividade privada, DNS e acesso administrativo. Evidências: diagramas, matrizes de fluxo, regras, tabelas de rotas, controles de egresso, testes e exceções.

8. Padrões Zero Trust e confiança serviço a serviço

Autenticar e autorizar conexões por identidade verificada, contexto e privilégio mínimo, e não apenas localização de rede. Evidências: arquitetura de confiança, identidades de serviço, políticas, certificados, testes e acessos negados.

9. Classificação, residência, soberania e ciclo de vida de dados

Classificar dados e mapear criação, armazenamento, processamento, replicação, backup, transferência e exclusão. Evidências: inventários, classificação, regiões, rotas de transferência, retenção e decisões de localização.

10. Criptografia, gestão de chaves, HSM e segredos

Definir criptografia em repouso e trânsito, propriedade e rotação de chaves, KMS/HSM, segregação de funções e gestão de segredos. Evidências: inventários, políticas, configurações, cofres, rotações, logs e exceções.

11. Logs, telemetria, trilhas de auditoria e integridade temporal

Habilitar eventos administrativos, identidade, rede, dados, workloads e plataforma; proteger logs e manter retenção e referência temporal consistentes. Evidências: padrão, fontes, saúde da ingestão, retenção, destinos protegidos e acessos.

12. Engenharia de detecção, monitoramento de ameaças e serviços nativos

Desenvolver detecções para abuso de credenciais, escalada, APIs suspeitas, recursos expostos, exfiltração e alterações de políticas. Evidências: regras, cobertura, testes, investigações, tuning e métricas.

13. Baselines de configuração e policy as code

Definir configurações seguras e avaliá-las ou aplicá-las por mecanismos de política quando apropriado. Evidências: baselines, repositórios, atribuições, resultados, bloqueios, exceções e remediação de drift.

14. Governança de infraestrutura como código e controle de drift

Gerenciar infraestrutura por repositórios controlados, revisão, testes, aprovações e pipelines protegidos. Evidências: repositórios IaC, revisões, planos, resultados, relatórios de drift e reconciliação.

15. Vulnerabilidades, patches, imagens e dependências

Inventariar e priorizar vulnerabilidades conforme exposição, explorabilidade, criticidade e responsabilidade do provedor. Evidências: cobertura, achados, patches, alertas, tickets, exceções, retestes e avisos.

16. Segurança de contêineres, Kubernetes e orquestração

Proteger clusters, planos de controle, nós, registries, admissão, RBAC, namespaces, políticas de rede, segredos e imagens. Evidências: inventários, baselines, políticas, proveniência de imagens, revisões e alertas.

17. Segurança serverless, PaaS, serviços gerenciados e APIs

Aplicar controles específicos a funções, bancos gerenciados, filas, analytics, IA, APIs e outros PaaS. Evidências: inventários, políticas de API, configurações, logs, dados e decisões de risco.

18. Segurança SaaS e garantia de configuração do tenant

Governar administradores, federação, MFA, compartilhamento, colaboração externa, retenção, integrações e logs. Evidências: inventário SaaS, revisões de funções, avaliações, apps conectados e remediação.

19. DevSecOps, CI/CD, assinatura e integridade de build

Proteger repositórios, runners, sistemas de build, identidades de implantação, artefatos e registries. Evidências: pipelines, revisões de acesso, scans, artefatos assinados, atestações de proveniência e releases.

20. Backup, recuperação, imutabilidade e resiliência a ransomware

Definir cobertura protegida de backup, isolamento, imutabilidade quando apropriado, retenção e restauração. Evidências: políticas, inventários, testes de restauração, configurações, acessos e tempos observados.

21. Disponibilidade, resiliência regional e domínios de falha

Projetar segundo requisitos de resiliência entre zonas, regiões, serviços, identidade, redes, DNS, dados e fornecedores. Evidências: arquitetura, dependências, testes de failover, capacidade, limites e ações corretivas.

22. Resposta a incidentes, forense e preservação de evidências em nuvem

Preparar playbooks para comprometimento de identidade, exposição de dados, workloads maliciosos, ransomware e abuso do plano de controle. Evidências: playbooks, cronologias, snapshots, logs, casos com provedor, exercícios e lições.

23. Inventário, descoberta, propriedade e tagging de ativos

Identificar continuamente recursos, ativos efêmeros, endpoints públicos, dados, chaves, workloads e integrações. Evidências: feeds de inventário, conformidade de tags, recursos órfãos, atestações e limpeza.

24. Risco de terceiros, marketplaces e serviços gerenciados

Governar imagens de marketplace, SaaS, MSPs, APIs e componentes externos. Evidências: registro, avaliações, permissões, contratos, monitoramento e encerramento.

25. Garantia de fornecedores cloud e evidência contratual

Coletar asseguração proporcional ao risco e validar escopo e período de relatórios, certificações e compromissos. Evidências: relatórios, mapeamentos, contratos, achados, bridge letters e decisões.

26. Privacidade, registros, retenção e exclusão

Configurar serviços para apoiar obrigações aplicáveis de privacidade e records sem confundir capacidade técnica com determinação jurídica. Evidências: retenção, exclusão, legal holds, avaliações e testes de ciclo de vida.

27. Custos, capacidade, abuso e governança de recursos

Tratar custos inesperados, exaustão, abuso de quotas, criptomineração e provisionamento descontrolado como sinais quando relevante. Evidências: limites, alertas, capacidade, investigações e ações.

28. Consistência de controles multi-cloud e híbridos

Definir controles corporativos e específicos por provedor sem esconder diferenças materiais. Evidências: matriz cross-cloud, padrões, desvios, cobertura, lacunas e planos de migração.

29. Métricas, saúde de controles, monitoramento contínuo e exceções

Medir exposição privilegiada, recursos públicos, violações, lacunas de logging, risco sem patch, identidades obsoletas, falhas de backup e idade de exceções. Evidências: dashboards, definições, limites, tendências e remediação.

30. Avaliação, asseguração, testes e amostragem de evidências

Definir escopo, amostragem, validação técnica, revisão de configuração, testes e interfaces de avaliadores. Automação não cria certificação nem substitui julgamento profissional externo. Evidências: planos, amostras, workpapers, achados e retestes.

31. Migração, modernização, saída, portabilidade e descomissionamento

Planejar migrações e saídas seguras considerando dados, identidades, chaves, configurações, dependências, evidências e exclusão. Evidências: planos, testes de portabilidade, reconciliação, confirmação de exclusão e acessos revogados.

32. Pacote de evidências, roadmap, mudança de fontes e melhoria contínua

Registrar proprietário, escopo, procedimento, frequência, evidência, método de teste, achados, remediação e reavaliação. Revalidar versão CCM/CAIQ, transições, mapeamentos, orientação relevante e dependências STAR no release. Exigir paridade trilingue, seis binários reproduzíveis, QA de render/acessibilidade, SHA-256, segurança de workflows, staging exato, predecessor publicado e reconciliação dos registros.

Limite de liberação controlada

Esta localização não estabelece conformidade, equivalência jurídica, certificação de provedor nem status CSA STAR. CCM v4.1 é o estado de referência CSA registrado pelo gate de fontes e deve ser revalidado no release. Pela regra canônica, um candidato limpo com gates objetivos verdes e predecessor publicado prossegue sob autorização permanente salvo uma questão substantiva específica que exija julgamento especializado não determinístico.